Document 14 — Security, Privacy & Compliance Blueprint

Product Name: HQ

Tagline: Your AI Headquarters

Version: 1.0

Purpose

This document defines the security, privacy, compliance, and governance standards for HQ.

Security is treated as a foundational architectural principle rather than a feature added after development.

The objective is to protect users, organizations, business data, AI interactions, and platform operations while preparing HQ for future enterprise adoption.

Security Philosophy

HQ follows the principle of Secure by Design.

Every component should be:

- Secure by default
- Privacy-first
- Least privilege
- Continuously monitored
- Fully auditable
- Resilient against misuse

Security decisions should be made during design, implementation, deployment, and operations.

Security Objectives

HQ must protect:

- User accounts
- Organizations
- Headquarters
- Executive communications
- Mission data
- Assets
- Billing information
- AI interactions
- Infrastructure

Authentication

Supported methods:

- Email & Password
- Google Sign-In

Future support:

- Passkeys
- Enterprise Single Sign-On (SSO)

Authentication requirements:

- Secure password hashing
- Email verification
- Refresh tokens
- Session expiration
- Secure logout

Authorization

HQ implements Role-Based Access Control (RBAC).

Example roles:

- Owner
- Administrator
- Manager
- Member
- Viewer

Permissions determine access to:

- Missions
- Executive Board
- Billing
- Assets
- Analytics
- Organization settings

Organization Isolation

Every organization operates independently.

Users must never access:

- Another organization's missions
- Executive memory
- Assets
- Billing data
- Analytics

Tenant isolation is enforced throughout the application.

API Security

Every API endpoint must implement:

- JWT authentication
- Authorization checks
- Request validation
- Input sanitization
- Rate limiting
- Audit logging

Unauthorized requests are rejected before business logic executes.

Data Encryption

Sensitive information is protected using encryption.

Data in transit:

- HTTPS/TLS

Sensitive data at rest:

- Database encryption
- Storage encryption

Passwords are never stored in plain text.

Secret Management

Secrets include:

- API keys
- Database credentials
- OAuth credentials
- JWT secrets
- Payment provider secrets

Secrets are managed through Google Secret Manager and are never committed to source control.

File Security

Uploaded files must be:

- Size validated
- Type validated
- Malware scanned (future enhancement)
- Securely stored

Executable file uploads are prohibited unless explicitly supported.

AI Security

AI introduces unique security challenges.

HQ implements safeguards against:

- Prompt injection

- Prompt leakage
- Unauthorized data exposure
- Unsafe generated content
- Excessive AI usage

Executives only receive the context required for their assigned tasks.

AI Output Validation

Before AI-generated content is delivered:

The system verifies:

- Completeness
- Brand alignment
- Appropriate formatting
- Internal consistency
- Policy compliance

Low-confidence outputs may require additional review.

Executive Memory Protection

Memory is divided into:

Global Memory

- Shared organizational knowledge

Department Memory

- Department-specific information

Session Memory

- Temporary mission context

Access is restricted based on responsibility and organizational ownership.

Privacy Principles

HQ follows these principles:

- Data minimization
- Purpose limitation
- User transparency

- User control
- Secure retention
- Responsible deletion

Only information necessary for platform functionality should be collected.

Audit Logging

Security events include:

- Login attempts
- Permission changes
- Mission approvals
- Billing actions
- Administrative actions
- Deployment events

Audit logs support incident investigations and accountability.

Rate Limiting

Rate limits protect against abuse.

Applied to:

- Authentication
- AI requests
- API endpoints
- File uploads

Limits should be configurable.

Abuse Prevention

The platform detects:

- Automated abuse
- Excessive AI requests
- Credential attacks
- Suspicious login patterns
- Unauthorized access attempts

Mitigation strategies should be reviewed regularly.

Dependency Security

Dependencies must be:

- Regularly updated
- Vulnerability scanned
- Reviewed before adoption

Outdated or vulnerable packages should be replaced promptly.

Secure Development Lifecycle

Every feature follows:

Design

↓

Threat Review

↓

Implementation

↓

Testing

↓

Security Review

↓

Deployment

↓

Monitoring

Security remains part of the development lifecycle rather than a separate activity.

Incident Response

Security incidents follow a defined process:

Detect

Contain

Investigate

Recover

Review

Improve

Post-incident reviews should identify corrective actions.

Backup & Recovery

Critical data is backed up regularly.

Recovery procedures include:

Database restoration

Asset recovery

Configuration restoration

Infrastructure recreation

Recovery processes should be tested periodically.

Compliance Readiness

Although the MVP targets the hackathon, HQ should be designed with future compliance in mind.

Examples:

GDPR readiness

SOC 2 readiness

Privacy best practices

Compliance requirements should influence architectural decisions where practical.

Security Monitoring

Monitor:

Authentication activity

API errors

Failed requests

AI request failures

Infrastructure health

Storage usage

Monitoring enables proactive detection of issues.

Security Education

Engineering practices include:

Secure coding standards

Code reviews

Dependency management

Security awareness

Documentation updates

Security is a shared engineering responsibility.

Success Criteria

The Security, Privacy & Compliance Blueprint succeeds when:

User data remains protected.

Organizations remain isolated.

AI operates responsibly.

Infrastructure is resilient.

Security issues are detected early.

The platform is prepared for future enterprise requirements.

Conclusion

Security is fundamental to HQ.

By embedding security, privacy, and responsible AI governance into every layer of the platform, HQ establishes a trusted foundation capable of supporting both the hackathon MVP and long-term commercial growth.